21 – Agenten sicher betreiben

Definition: Agenten sicher betreiben heißt: Agenten mit minimalen Rechten, klaren Freigaben, Limits und Rückgängig-Plan nutzen, damit ein Fehler keine Katastrophe wird.

> **Merksatz:** So viel Freiheit wie nötig, so viel Kontrolle wie möglich.

Kernpunkte

- **Prinzip der minimalen Rechte:** Der Agent bekommt nur, was die Aufgabe braucht – Lesen vor Schreiben, nur bestimmte Ordner oder Konten, keine Vollzugriffe „zur Sicherheit“.
- **Human-in-the-loop:** Der Mensch bestätigt Aktionen mit Folgen: Senden, Löschen, Bezahlen, Veröffentlichen, Ändern von echten Daten.
- **Testumgebung zuerst:** Neues erst mit Testkonto und erfundenen Daten ausprobieren, nie direkt mit echten Dateien oder Konten.
- **Protokolle prüfen:** Was hat der Agent wann getan? Nutzungshistorie und Logs regelmäßig ansehen, besonders nach ersten Läufen.
- **Limits setzen:** maximale Schritte, Zeitbudget, Ausgabenlimit (Thema 15). So kann ein Fehler nicht unbegrenzt weiterlaufen.
- **Rückgängig-Plan:** Backups vor dem ersten Lauf, Versionierung für Dateien, Notaus (Zugriffe widerrufen, Agent stoppen).
- **Warum das wichtig ist:** Agenten kombinieren die Risiken aus Injection (Thema 12) und Tools (Thema 11) – fremde Inhalte können sie zu Aktionen verleiten. Guardrails (Thema 13) sind deine zusätzliche Leitplanke.

Checkliste: Vor dem ersten Einsatz

- ☐ **Rechte:** Welche Zugriffe braucht die Aufgabe wirklich? Alles andere weg.
- ☐ **Limits:** Wie viele Schritte, wie lange, wie teuer darf der Lauf werden?
- ☐ **Freigaben:** Welche Aktionen bestätigt der Mensch immer selbst?
- ☐ **Backup:** Kann ich alles zurückholen, was der Agent ändert?
- ☐ **Notaus:** Wie stoppe und widerrufe ich schnell?

Beispiel

Ein fiktiver Mail-Agent soll deine Beantwortung von Standardanfragen vorbereiten.

Prüfpunkt	Unsicher	Sicher eingerichtet
Rechte	Vollzugriff auf Postfach	Lesen auf Ordner „Eingang“, Entwurf-Erstellen
Freigaben	Agent sendet selbst	Agent legt nur Entwürfe an, du sendest
Testumgebung	direkt am echten Postfach	Testkonto mit erfundenen Mails
Limits	unbegrenzt	max. 20 Mails pro Lauf, max. 10 Min.
Rückgängig	keine	Entwürfe bleiben im Ordner, nichts wird gelöscht

Sicherheit kostet hier kaum Komfort: Der Agent tut seine Arbeit, aber die einzige Aktion mit Folgen – das Senden – bleibt bei dir.

Do / Don’t

Do	Don’t
Minimale Rechte vergeben	Vollzugriff aus Bequemlichkeit
Jede Aktion mit Folgen selbst bestätigen	Dem Agenten „einmal kurz“ vertrauen
Erst in der Testumgebung üben	Neue Agenten direkt an echten Daten testen
Logs und Limits prüfen	Läufe unbeaufsichtigt laufen lassen

Sicherheitshinweis

Kein technischer Schutz ersetzt die Freigabe. Betrachte jeden Agenten-Lauf wie einen neuen Mitarbeiter an seinem ersten Tag: fähig, aber ohne Urteilsvermögen über die Folgen.

Mini-Checkliste

- ☐ Ich kenne die fünf Prüfpunkte der Checkliste.
- ☐ Ich halte Rechte minimal (Lesen vor Schreiben).
- ☐ Ich bestätige Senden, Löschen, Bezahlen und Veröffentlichen selbst.
- ☐ Ich habe einen Notaus: Stoppen und Zugriffe widerrufen.
- ☐ Ich habe Backups, bevor ein Agent etwas ändert.

Übung (5 Min.)

Nimm den fiktiven Mail-Agenten aus dem Beispiel oder einen eigenen Anwendungsfall (z. B. Datei-Sortierer, Terminplaner). Fülle die Checkliste „Vor dem ersten Einsatz“ aus. Wo machst du Abstriche? Sind sie begründbar?

Weiter

- Zusatzübungen: `02_zusatzuebungen/21_zusatzuebungen`
- Test: Test E (Agentische Systeme)
- Verwandt: 12 Prompt Injection, 13 Guardrails, 16 Agents, 17 MCP, 15 Kostenkontrolle

Stand: Oktober 2026